ThreatScope: Bounded Evidence Sharing, Threat Correlation, and Grounded Local AI

Ananay Srivastava, Jitendra Singh, Manik Bhardwaj, Ashish Jain, Mukunj Singh

Department of Computer Science and Engineering, Sharda University, Greater Noida, India

***Abstract*—Collaborative threat detection needs evidence from several organizations, but routine log export exposes information that an incident may not require. A local language model can then add unsupported detail or repeat evidence that has been corrected or withdrawn. We implement a common evidence lifecycle addressing both boundaries. Organizations retain raw events, send versioned signals, and approve, coarsen, or deny finite catalogue requests. A coordinator requests the least costly untried predicate while a declared rule remains unresolved, accounts for provenance groups, and records supported, contradicted, or unresolved outcomes. A separate local explanation process proposes finite claims against a recipient-authorized evidence snapshot. Exact tuple verification and current-snapshot checks precede controlled rendering; failed generation uses a deterministic fallback. In 1,000 synthetic protocol cases, the no-fault adaptive strategy matched the richer baseline's declared-rule outcomes with 18.2% fewer policy units and 13.2% fewer serialized payload bytes. In a separate eight-case Qwen3-4B CPU pilot, the complete explanation method displayed zero unsupported claims among 46, but fell back in every case and incurred a median generation time of 146.7 seconds. The studies demonstrate bounded protocol behavior and evidence-version enforcement. They do not establish field detection accuracy, formal privacy, analyst usefulness, or a benefit from model generation over templates.**

***Index Terms*—collaborative threat detection, selective disclosure, evidence provenance, local inference, claim verification, evidence lifecycle**

I. Introduction

An organization can observe an authentication burst without knowing whether other organizations see the same pattern. A coordinator can seek corroboration, but raw login records expose identities, timings, and internal topology. A high anomaly score also leaves alternatives open: credential rejection and an identity-provider outage may both produce failed logins. Useful collaboration must establish which additional observations are needed and preserve the owner's authority to refuse them. NIST guidance makes sharing participation and handling explicit decisions [1]; MISP demonstrates practical collaborative intelligence exchange [2].

The interpretation boundary adds another problem. An analyst may receive an incident outcome with some fields intentionally withheld. A fluent local model can turn partial evidence into an account that names an attacker or asserts a successful compromise. A previously valid report may also become inaccurate or unauthorized when evidence changes. Local execution changes the location of inference; it does not establish that each statement remains supported.

We connect these boundaries through versioned evidence. The disclosure protocol produces finite, owner-approved records. Correlation attributes its outcome to declared rules and independent enrolled provenance groups. The explanation service uses only the recipient's current authorized snapshot and renders admitted claims with controlled wording. The model cannot request raw records, change the incident outcome, or execute advice. This creates an inspectable path from a local observation to a displayed claim.

The contributions are an implemented finite disclosure protocol with cumulative local accounting, a recipient-specific claim contract with invalidation, and two component evaluations with explicit negative findings. The protocol evaluation compares sharing strategies while holding the workload constant. The explanation pilot checks claim support and lifecycle failures. These are separate studies: the pilot snapshots are constructed cases, and no experiment measures the complete live path from network events to analyst task outcomes.

II. Related Work and Contribution Boundary

A. Sharing and collaborative correlation

Controlled predictive blacklisting studies how much information collaborators should share [3]. STIX supplies a threat-information representation [4], although our wire contract does not claim STIX compliance. Sanitized security-alert correlation [5] and secure aggregation in SEPIA [6] establish earlier collaborative privacy mechanisms. Over-threshold multiparty private set intersection supports cross-network intrusion detection while protecting nonmatching information [7]. Our categorical releases provide administrative controls rather than those cryptographic guarantees.

Incremental disclosure is also established in record linkage [8]. A large empirical threat-intelligence community study distinguishes aggregation of existing intelligence from additional coverage [9]. Accordingly, requesting information on demand and counting messages are insufficient novelty claims. Our protocol ties a finite request sequence to an unresolved security rule, local cumulative debits, immutable retry responses, and explicit outcomes when useful evidence is unavailable. Operator-assigned provenance groups remain an assumption about independence.

B. Local models and supported explanations

Hackphyr studies a local network-security agent [10]; RedSage develops a cybersecurity generalist model [11]. ALCE

evaluates generation with citations [12], RARR studies attribution and revision [13], and FActScore decomposes factual evaluation into atomic claims [14]. LEXIS generates structured security-report drafts from detector explanations [15]; agentic alert investigation uses constrained queries over logs [16]. GSAR provides typed grounding and bounded recovery [17]. These methods establish close precedents for supported reporting and recovery.

Revocation research shows that marking memory as withdrawn can leave it authoritative to a generator [18]. SHAP-based cybersecurity interpretation concerns influential detector features [19]. RefChecker checks extracted claim triplets against references [20], whereas SelfCheckGPT uses sampling consistency [21]. FaithLM examines whether explanations reflect a model's decisions through interventions [22]. Our exact finite tuple checks establish fidelity to an authorized snapshot, not causal explanation faithfulness or unrestricted natural-language truth.

C. Evaluation and trust assumptions

CIC-IDS2017 supplies labelled network traffic and documented attack periods [23], [24]. Our planned replay remains uncompleted; the reported protocol cases are synthetic. Differential privacy has a formal neighbouring-dataset definition [25]; our integer release units are not its privacy parameter. CCE studies serverless security-event correlation [26]; our single worker instead simplifies durable state ownership. Indirect prompt injection motivates treating evidence text as untrusted [27]. Confidential accelerator execution protects against an untrusted host [28], a guarantee absent from our ordinary local CPU deployment. Qwen3 provides the evaluated model family [29]. Local-cloud offloading research considers joint quality, latency, and cost trade-offs [30]; our fixed local pilot does not evaluate cloud offloading.

III. System and Evidence Model

A. Trust boundaries and durable state

Three separately enrolled organization agents retain raw observations and independent SQLite WAL release ledgers. Enrollment maps a random credential, stored as a hash, to its organization and node identity. FastAPI authenticates and validates a typed signal, commits a PostgreSQL inbox record, and only then acknowledges acceptance. PostgreSQL stores incidents, requests, evidence versions, browser sessions, explanation jobs, and notification history. An advisory lock permits one inbox correlation worker owner. Evidence responses and revisions also evaluate incidents under database row locks; correlation is not authoritative process-local memory.

Each signal includes stable signal and snapshot identifiers, schema and detector versions, a UTC observation interval, anomaly family, score, policy version, and provenance identity. Conflicting reuse of an identifier is rejected. Default correlation uses a 120-second tumbling window, score threshold 0.80, quorum of three enrolled provenance groups, and a 90-second request deadline. These defaults are operational choices, not optimized research parameters. Unknown fingerprints cannot corroborate unrelated anomalies. Model readiness describes local training progress and does not suppress a rule score during warmup.

The coordinator may be curious, and an enrolled source may be compromised. Authentication establishes who submitted a value; it does not establish its truth. Provenance groups are assigned by an operator and do not prove independent sensing. Shared upstream telemetry, colluding groups, or fabricated aggregates can defeat corroboration. A database outage prevents durable acceptance; agents retain pending work. Restart recovery is supported, but one database and worker remain availability limits.

B. Catalogue and outcomes

Authentication evidence consists of failure-rate category (cost 1), source spread (cost 2), and failure kind (cost 2). Traffic uses request-rate category (cost 1), source spread (cost 2), and service-error category (cost 1). Values are enumerated; raw addresses, log paths, arbitrary query strings, and unrestricted metric maps have no catalogue representation. Initial signals cost one policy unit. Coarsening returns `unknown` with zero refinement cost in the tested policy.

For source o and family f, let $d_f(V_o) \in \{S, C, U\}$ represent support, contradiction, or unresolved from active released values V_o. Authentication support requires high failures, wide sources, and rejected credentials. Low failures, narrow sources, or service-unavailable failures contradict that rule. Traffic support requires spike rate, wide sources, and high service errors; normal rate or low errors contradict it. Every other combination remains unresolved. These are declared scenario predicates, not general definitions of attacks.

Only one source snapshot represents an organization within an incident. Reports in one provenance group must agree to produce a group vote. At least three supporting groups yield support; three contradicting groups yield contradiction; simultaneous quorums yield unresolved conflict. Denial, missing evidence and timeout never supply a support vote. Analyst workflow status, such as investigating or resolved, is stored separately from these evidence outcomes.

IV. Disclosure and Interpretation Method

A. Bounded adaptive disclosure

For an unresolved source with no pending request, the coordinator chooses

$$e^* = \operatorname*{arg\,min}_{e \in E_f \setminus (A_o \cup V_o)} (c(e), \mathrm{id}(e)), \tag{1}$$

where E_f is the family catalogue, A_o the attempted entries, and lexical identity breaks cost ties. The source rule is recomputed after each response. Selection stops after a decision, refusal, exhaustion, expiry, or lack of useful authorized evidence. The rule adapts through stopping; it does not estimate information gain or prove a globally optimal request sequence.

The owner checks the request's identity, recipient, catalogue entry, deadline, snapshot and current policy. Approval stores the exact representation and charge in one

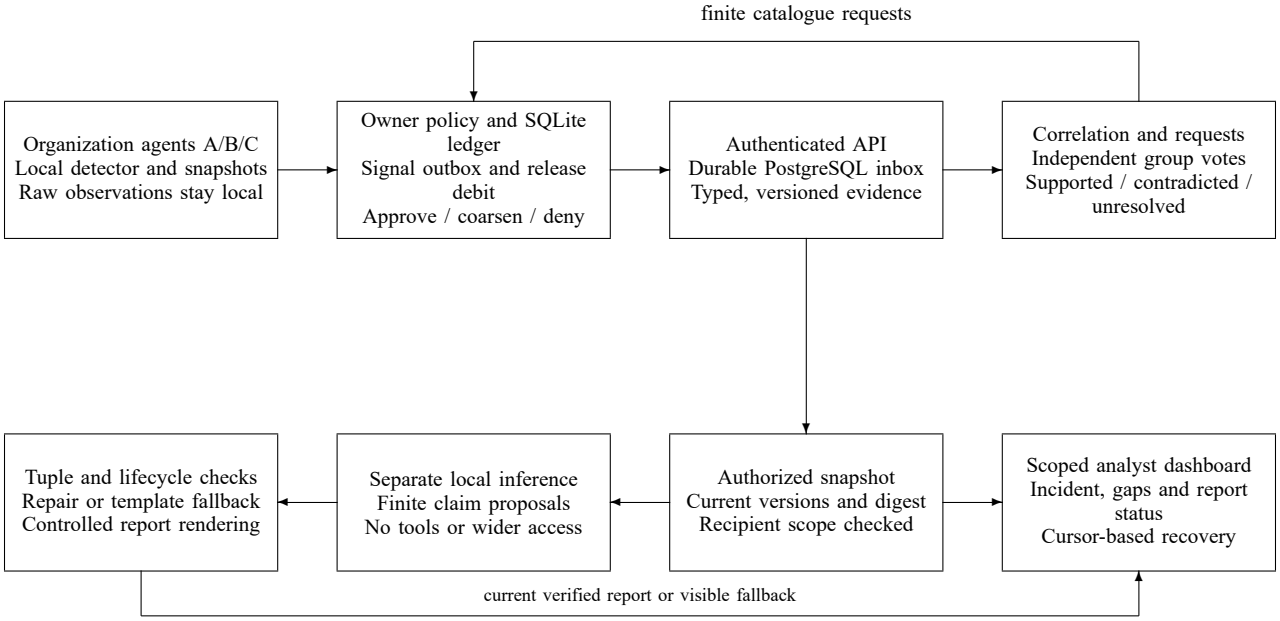


Fig. 1. Common evidence lifecycle. Owner-approved releases support correlation; a separate local process proposes claims from recipient-authorized snapshots. Current-version checks also apply before a report is served.

SQLite transaction before transmission. The release key is $(\text{snapshot}, \text{recipient}, \text{entry})$, so different request identifiers cannot charge or disclose that entry repeatedly. Retries reuse the immutable response. A tighter policy can deny its later delivery; it cannot erase a value already received. Per-snapshot and rolling-hour caps span retries and overlapping investigations. Concurrent cap checks execute inside the write transaction. Failure before commit exposes neither charge nor response.

One denial terminates further requests to that source for the investigation. An unavailable or coarse value can leave an incident unresolved, with its reason and coverage visible. This conservative rule protects release authority while sacrificing some liveness. Increasing catalogue size, deadlines or budgets changes that trade-off and requires separate evaluation.

B. Authorized claims and report lifecycle

For analyst recipient r, the API constructs current snapshot E_r from authorized active evidence, incident outcome, anomaly family and coverage. Each evidence item has an identifier and version; the snapshot has a digest $h(E_r)$. A model proposes $c = (t, p, v, e, k)$: type, predicate, value, optional evidence identifier and optional version. Types distinguish observation, inference, unknown and advice. The finite predicates are evidence value, outcome, family, coverage and a fixed local-log-review suggestion.

Admission is

$$A(c, E_r) = R(c, E_r) \wedge V(c, E_r) \wedge K(c, E_r) \wedge P(c, E_r), \quad (2)$$

where the checks resolve references, exact versions, allowed kinds and predicate/value tuples. Authorized snapshot construction is a precondition. An evidence citation alone cannot admit arbitrary prose. A high failure-rate category may be reported as an observation; it cannot license an exact password count, named actor or successful compromise absent from the vocabulary.

Admitted tuples receive controlled wording. Free-form model commentary is omitted. One bounded repair may use the same snapshot and failure list. Invalid JSON, unsupported tuples, timeout or unavailable inference lead to a deterministic report containing permitted facts and unknowns. A correction, withdrawal, expiry or changed permission invalidates old snapshots and dependent reports. Current authorization and digest checks occur before reuse, including when permissions change during generation. Detection continues independently of explanation availability.

C. Implementation and scope

The local endpoint uses `llama.cpp` with an interchangeable model, bounded context and response size, one concurrent generation, and at most 512 output tokens. The pilot uses Qwen3-4B Q4_K_M; a smaller 1.7B configuration is available but does not share the pilot's result. The model has no shell, network tools or raw-log query capability and no automatic cloud fallback. A second-laptop endpoint requires authenticated TLS and certificate verification; the measured pilot uses loopback transport.

Browser sessions use HttpOnly cookies, origin and CSRF checks, and incident-scoped permissions. Bounded subscriber queues and cursor recovery keep slow dashboards outside ingestion work. Migrations preserve legacy records but quarantine evidence lacking verified identity/provenance. Source storage and derived values remain sensitive. Local execution, transport authentication and policy units provide different

TABLE I
NO-FAULT PROTOCOL SLICE: 50 CASES PER STRATEGY.

Strategy	TP	FP	Units	Releases	Bytes
Local only	20	20	0	0	0
Fixed minimal	20	20	120	0	48,180
Fixed richer	20	0	660	360	230,460
Static escalation	20	0	660	360	230,460
Decision driven	20	0	540	300	200,100

TABLE II
SEPARATE EIGHT-CASE QWEN3-4B CPU PILOT.

Condition	Claims	Unsupported	Fallbacks	Median s
Template	46	0	0	< 0.01
Direct	20	10	0	53.0
Cited	20	8	0	86.6
No lifecycle	48	3	8	n/a
Complete	46	0	8	146.7

controls; none establishes anonymity or formal differential privacy.

V. EVALUATION

A. Disclosure protocol experiment

Five labelled scenarios are normal traffic, authentication attack, provider outage, traffic attack and flash crowd. Ten seeds, three synthetic nodes and a ten-second event window produce 50 cases per strategy/condition cell. Labels remain in the evaluator. Local only, fixed minimal, fixed richer, static escalation and decision driven are tested under no fault, denial, source-spread coarsening and a two-unit snapshot cap. The factorial design yields $5\times10\times5\times4 = 1{,}000$ records. Synthetic partitions are not independently operated organizations.

We count attack-labelled cases supported (TP), benign cases supported (FP), unresolved outcomes, policy units, refinements and serialized signal/request/response bytes. The byte metric excludes HTTP/TLS headers, retransmission and dashboard traffic. Local protocol timing excludes network transit. The generated labels and scenario predicates share a known design, so these measurements test the disclosure protocol rather than independent detector generalization.

Decision driven matches the richer baseline's 20 supported attacks and zero supported benign cases in the no-fault slice (Table I). It saves 120 policy units (18.2%), 60 refinements (16.7%) and 30,360 payload bytes (13.2%). Savings arise in provider outages and flash crowds, where contradiction stops further requests. Neither attack scenario saves bytes because all supporting predicates are needed. A deployment with fewer short-circuit benign cases may realize less saving.

Denial and budget exhaustion each leave 40 of 50 decision-driven cases unresolved; coarsening leaves 20 unresolved. Each fault condition has zero supported attacks and zero supported benign cases. Consequently, the absence of false positives under these faults also reflects withheld attack decisions. Reporting only the false-positive count would conceal the operational cost of limited disclosure.

B. Local explanation pilot

Eight frozen cases cover support, contradiction, partial coverage, withdrawal, correction, restricted evidence, an instruction-like note and deliberate model failure. They compare templates, direct generation, citation prompting, verification without lifecycle checks and the complete method. These are separate synthetic snapshots, not output cases from the 1,000-record study. Lifecycle cases generate against an initial snapshot and score against the current one. The no-lifecycle ablation reuses cited raw output and validates against the initial snapshot, avoiding an extra random sample.

The host runs Windows on an AMD Ryzen 5 4500U with six logical processors, about 20.9 GB RAM, four inference threads, context 8192 and concurrency one. Each parseable claim is unsupported if it fails the current finite contract. This includes outdated, unauthorized and out-of-vocabulary claims; it is not an independent human judgement that a sentence is false. Invalid structures and failure cases are reported separately.

Direct generation has one failure and two invalid-contract cases; citation prompting has three failures. Initial-snapshot verification retains one unsupported claim each in withdrawal, correction and restriction. The complete method uses current-snapshot invalidation and ultimately falls back in all eight cases, displaying zero unsupported claims among 46. Median generation time includes the initial attempt and any repair; it excludes analyst task time and is not fallback-rendering time. The no-lifecycle ablation has no independent timing measurement.

Templates and the complete method enumerate the same allowed set, so their perfect finite coverage is expected by construction. The result establishes a checked boundary with a negative model result. It does not show improved usefulness, semantic understanding or practical speed over templates. No analyst study, independently labelled field dataset or full-system performance study has been completed.

VI. CROSS-BOUNDARY WORKED TRACE

Consider three synthetic organizations observing an authentication anomaly in the same correlation bucket. Each initial signal reports a qualifying score, but the coordinator cannot determine whether rejected credentials or provider unavailability explains the failures. The trace is an illustration of the implemented catalogue and state transitions, not an additional experimental run. No raw username, address or login record is disclosed.

The first requested entry is `auth_failure`, because it costs one unit. Suppose each source approves `high`. The source rules remain unresolved. The next cheapest entry is `failure_kind`; its cost ties with `source_spread`, and lexical ordering selects it first. If each source returns `unavailable`, the rules contradict the attack hypothesis. Three independent enrolled groups then produce a contradicted incident. Source spread is no longer requested. A fixed richer strategy would still attempt that remaining entry. The savings are therefore a consequence of a declared short-circuit alternative, not an inferred statistical privacy gain.

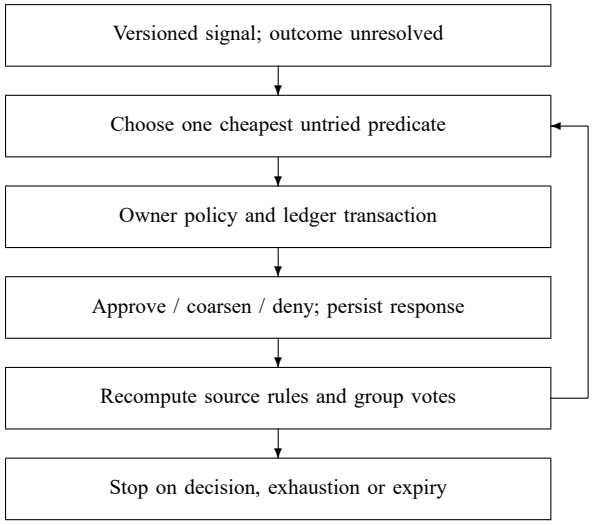


Fig. 2. Disclosure control loop. A refused request closes further requests to that source in the investigation.

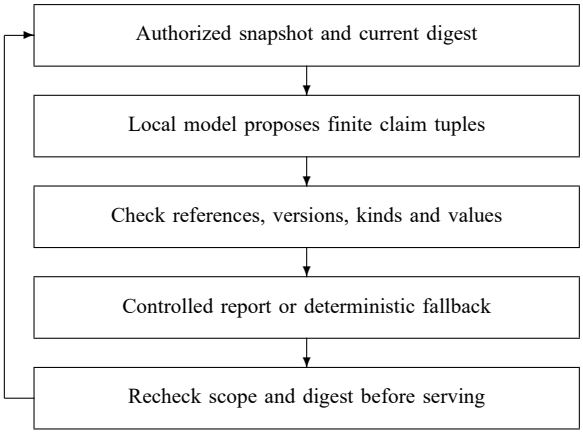


Fig. 3. Interpretation lifecycle. A single repair uses the same evidence; it cannot expand the recipient's authority.

Each agent commits its approved response and debit before sending. If a response arrives but the acknowledgement is lost, the agent retransmits the stored representation under the same release identity. It does not recompute a new fine-grained answer. Different network request identifiers referring to the same snapshot, recipient and entry still resolve to that representation. If policy tightens before the retransmission, the agent can deny further delivery of the old fine value. This cannot retract the copy that the coordinator already received.

An authorized analyst snapshot may contain the approved failure kind and the attributed incident outcome. The explanation can say that the source reported service-unavailable failures and that the declared authentication rule was contradicted. It cannot say that the organization was free of every attack. The rule concerns one scenario family and observation scope, and a contradicted hypothesis does not establish the absence of unrelated threats. For an organization analyst whose scope excludes other organizations' refinements, the authorized snapshot contains a smaller evidence set than the coordinator's view.

Now suppose a source corrects its failure kind to `mixed`. The new version no longer supplies the contradiction used in the earlier three-group outcome. Correlation recomputes the incident, and its evidence-dependent explanation becomes stale. The report service checks the new digest before returning a cached report. It may render the current outcome and coverage, while declining to repeat the unsupported earlier conclusion. This illustrates how one version change can affect both a group vote and a displayed claim. The synthetic component studies do not measure the latency of this entire trace.

VII. Accounting and Lifecycle Invariants

For snapshot s, recipient r and entry e, the organization ledger stores at most one representation, $|L_o[s, r, e]| \leq 1$. Approved releases debit their catalogue cost; denied and coarsened refinements debit zero under the tested policy. Both the representation and debit belong to one local transaction. The initial signal has its own accounted release before entering the signal outbox. At commit, the per-snapshot and rolling-hour checks enforce

$$\sum_{x \in L_o(s)} c_x \leq B_s, \qquad \sum_{x \in L_o[t-3600,t]} c_x \leq B_h. \tag{3}$$

The current deployment defaults are six units per snapshot and 2,400 units over the preceding hour. New requests, overlapping investigations and policy version changes do not clear accumulated local charges. The bound spans snapshots on one enrolled agent; it is not a cryptographic global disclosure theorem.

The coordinator and owner transactions are separate. A lost message after the owner commits can consume budget without supplying evidence in time. This leaves the incident unresolved rather than allowing an uncharged release. If the owner loses its SQLite file, the release history cannot be assumed intact; recovery needs an operator procedure before the identity resumes. Eventual retries improve delivery only while the investigation remains eligible. The paper does not prove liveness under unbounded partitions.

Evidence has a 24-hour expiry in the prototype. Retrieval masks expired evidence, while the worker persists expiry revisions. Corrections, withdrawal and permission changes alter the recipient snapshot. A report digest covers the whole authorized snapshot, so even a change to an unmentioned item can invalidate the report. This conservative approach costs regeneration; it avoids claiming a precise dependency analysis for implicit model reasoning. An audit copy is historical and must not be served as the current report without current checks.

The admission invariant concerns displayed tuples: a factual claim must match the permitted set computed from the current authorized snapshot. It does not establish source truth. If the

model outputs an arbitrary statement with a valid citation, membership still fails when its predicate or value is outside the finite contract. Controlled rendering preserves the admitted meaning. Allowing unrestricted paraphrasing after that check would introduce another unverified generation boundary.

VIII. Closest Methods and Measurement Detail

Table III compares mechanisms, not benchmark rankings. Different input assumptions and output meanings prevent importing a published accuracy figure into our finite-contract score. Cryptographic matching, detector-feature interpretation, natural-language entailment and authorization checks answer different questions. A future direct comparison needs a common task specification and must expose where a comparator cannot express the same operation.

In the eight-case pilot, withdrawal, correction and restriction each leave one unsupported claim after initial-snapshot verification. Citation prompting improves the contradicted case but worsens the corrected case relative to direct generation. Thus its lower aggregate unsupported count does not mean that every evidence condition improves. The complete method's current-state behavior is coupled to fallback throughout, so it does not isolate a successful model contribution.

Finite-claim coverage is 1.0 for template and complete, 0.979 for no-lifecycle, 0.221 for direct and 0.267 for cited output. The denominator is the programmatic allowed-claim set. Exhaustive templates are favoured by this measure; it is not analyst usefulness. A failed model call can also have zero unsupported claims because it emits none. Failure, invalid structure, raw claim count and fallback rate must accompany the support measure.

All values in the no-fault disclosure table are sums over 50 cases, while the explanation table aggregates eight constructed snapshots. These denominators must remain distinct. Neither is a population sample of independent deployments. The separate pilot cannot show that 18.2% less disclosure preserves an analyst's useful explanation coverage, because the evaluated snapshots were not generated by those disclosure runs.

IX. Coupled Evidence States and Evaluation Gap

The combined design has two views of incompleteness. Correlation sees whether released predicates can decide its rule, while interpretation sees what the current recipient may receive. A coordinator can have enough cross-organization evidence to record support even when an organization analyst cannot see every contributing refinement. The analyst report may state the attributed incident outcome and permitted coverage, but it must not reconstruct those hidden values. This is an authorization limit on explanation detail, not a reason to change the coordinator's outcome.

Conversely, a complete visible record does not require a model to narrate it. The fallback already constructs the permitted facts. A generator's contribution must therefore be defined in terms of a task that templates cannot satisfy adequately, such as prioritizing supported observations for a specified analyst decision. The current finite vocabulary excludes unrestricted priority judgements, and no useful-prioritization result is reported. Extending that vocabulary requires new admission rules and independent evaluation rather than permitting arbitrary commentary after verification.

A joint study must preserve the same source observations while varying disclosure policy. It should record the final rule outcome, recipient-visible snapshot, admitted claims, omitted allowed claims, fallback reason and timing for each case. Withholding a predicate may increase unresolved incidents and reduce available report detail at the same time. Those effects cannot be inferred from the two separate component totals. The denominator for claim coverage must be the snapshot actually authorized in that condition, while a separate task label measures whether the remaining information is useful for the analyst's question.

Corrections need another control. A changed snapshot can make a report stale without changing the incident outcome. An authorization change can remove visible evidence while leaving the coordinator's rule result intact. A test should exercise both and distinguish a correctly invalidated report from a missed security transition. Similarly, a model failure should leave the incident available and cause a visible template result, not enter the detector's error count. These distinctions prevent a single aggregate success measure from concealing different failure boundaries.

This is a proposed evaluation protocol. The existing eight-case pilot establishes current-state checks over constructed snapshots, and the disclosure study establishes its own policy/outcome behavior. Neither supplies the matched incident records required to estimate the joint effect. Keeping that gap explicit allows later experiments to address it without retroactively presenting component measurements as full-system validation.

X. Fault Analysis and Reproducibility

The fault matrix is more informative than a single headline reduction. Under no fault, fixed richer, static escalation, and decision driven all resolve the two attack scenario families and benign alternatives according to the declared rules. Under the denial fault, the distinguishing `failure_kind` and `service_errors` entries cannot be released. The 40 abnormal cases remain unresolved for decision driven; the ten normal cases have no candidate and remain `none`. Under a two-unit snapshot cap, the initial signal consumes one unit and there is insufficient space for all required predicates. Again 40 abnormal cases are unresolved. Under source-spread coarsening, the unknown category prevents confirmation of the two attack scenarios while some benign alternatives still contradict without it, yielding 20 unresolved cases. These patterns are consequences of the fixed rules and policy, not estimates of how frequently faults occur in production.

The same 50 scenario–seed pairs are replayed for every strategy and fault. This pairing permits a direct within-harness comparison of totals but does not justify a confidence interval over unrelated organizations. The synthetic generator creates

TABLE III
CLOSEST MECHANISMS AND THE NARROW BOUNDARY EXAMINED HERE.

Method	Established mechanism	Boundary of this study
Controlled blacklisting [3]	Controlled collaborator sharing for prediction	Finite incident predicates, source-owned retry ledger and unresolved outcomes
SEPIA / multiparty PSI [6], [7]	Cryptographic aggregation or protected threshold matching	Policy-controlled categories; no equivalent cryptographic guarantee
LEXIS [15]	Security-report drafts from detector explanation evidence	Exact current recipient snapshot and finite claim admission
ALCE / RARR [12], [13]	Citation generation and evidence-based revision	A cited claim also needs exact allowed value, version and scope
GSAR [17]	Typed grounding judgement and recovery actions	Deterministic tuple membership and an explicit one-repair limit
Revocation study [18]	Empirical retrieval failures despite withdrawn status	Current snapshot invalidation before a report is reused

TABLE IV
THREE DISCLOSURE STRATEGIES UNDER EACH FAULT; CELLS ARE TP/FP/U ACROSS 50 CASES.

Fault	Richer	Static	Decision
None	20/0/0	20/0/0	20/0/0
Deny	0/0/40	0/0/40	0/0/40
Coarsen	0/0/20	0/0/20	0/0/20
Budget	0/0/40	0/0/40	0/0/40

10-second windows with 30 requests/s for normal, 200 requests/s for authentication attack and provider outage, and 800 requests/s for traffic attack and flash crowd. Authentication failures are marked with 401 status in the attack and 503 status in the outage. Traffic attacks inject elevated 503 responses. The source spread threshold is ten distinct addresses. These settings deliberately create two tempting benign alternatives for a coarse alert. They are disclosed here so a reader can see that the evaluation is a protocol test shaped around the implemented rules.

The result files are `research/results/disclosure.csv` and `research/results/summary.json`. The executable harness is `research/evaluate_disclosure.py`; the case manifest and digest are `research/cases.json` and `research/cases.sha256`. The evaluator refuses to run if the manifest digest differs or the output CSV already exists, protecting an existing measurement from accidental overwrite. Each run creates separate organization ledger paths by fault, seed, scenario, and strategy. The summary script aggregates the recorded CSV rather than regenerating results. Tests cover API contracts, ledger behavior, durable recovery, and evidence lifecycle; integration checks also exercised migrations, backup/restore, frontend build, and a three-organization local demo. The paper's numerical claims should be rechecked against those files whenever the implementation changes.

A. Interpretation of cost and transport

The 18.2% policy-unit reduction and 13.2% serialized-byte reduction in the no-fault slice are different quantities. An approved `source_spread` costs two units but its JSON body need not be twice as large as another predicate. Conversely, a zero-unit coarse response still consumes bytes and can reveal that the owner was queried. The measured payload also counts each request, which explains why fewer releases do not imply an equal percentage byte reduction. The static escalation strategy has the same units and bytes as fixed richer but a different round count because its schedule sends requests sequentially. No bandwidth measurement over TLS or WAN was recorded. A deployment claim about transfer cost therefore needs a network trace, compression and batching policy, and realistic retransmission rates.

B. Sensitivity to correlation assumptions

The harness uses three nodes and a three-vote outcome. If quorum were reduced to two, one faulty or colluding pair could dominate; if increased above three, these cases could never resolve. If the temporal bucket were wider, unrelated events could be combined; if narrower, concurrent observations might split. The manuscript reports configured defaults rather than claiming they are optimized. A deployment should measure clock skew, base rates, organization overlap, and correlated detector errors before selecting quorum or a time window. Provenance labels are crucial because three feeds forwarding one sensor are not three independent observations. The current tests verify deduplication logic, while empirical independence of real organizations remains unmeasured.

C. Accounting under the fault interventions

The cost matrix in Table V separates a stopping-rule benefit from a policy constraint. Without faults, decision driven spends fewer units than fixed richer because it does not request the third predicate for two benign alternatives. Under denial, it spends half as many units as fixed richer because it stops at the first denied decisive entry for each affected source. The saved units in this condition have a different meaning from no-fault savings: the unresolved count rises to 40, so the coordinator has paid less partly because it could not finish. The coarsening condition gives the same total policy units for the three richer strategies, even though decision driven sends fewer bytes than static escalation. The budget condition binds before the full catalogue can be released, so all three richer strategies spend 240 units and leave 40 abnormal cases unresolved. These interventions demonstrate why a paper should report utility and exposure together.

The fixed-minimal line is constant because it sends only the initial signal, which is allowed in these synthetic policies. Its

TABLE V
AGGREGATE POLICY UNITS PER 50-CASE FAULT SLICE.

Strategy	None	Deny	Coarsen	Budget
Local only	0	0	0	0
Fixed minimal	120	120	120	120
Fixed richer	660	480	420	240
Static escalation	660	480	420	240
Decision driven	540	240	420	240

apparent robustness to faults is misleading: it also produces the same 20 false positives in every slice and never tests the distinguishing predicates. Local-only incurs no sharing units, but it makes the same 20 false-positive support decisions and provides no cross-organization corroboration. These baselines bound two extremes: no cross-boundary evidence and initial-signal-only sharing. They are useful controls, not realistic final incident adjudicators. An analyst could manually resolve their alerts with data that the harness does not model.

The denial policy is especially instructive. In authentication, the first cheap failure-rate category can be approved but the later failure-kind category is refused. In traffic, request rate is approved but service errors are refused. The coordinator learns that an anomaly exists and learns one additional category, yet it cannot determine support or contradiction for either family. A naive implementation might count "no contradicting response" as support. The explicit unresolved state prevents that inference. It also has a cost: the organization has already released some information without delivering a final classification. If denials are frequent, an owner might prefer policy-aware negotiation before any release, such as advertising which catalogue entries it permits. That would reduce wasted partial disclosure but reveal policy configuration itself. We did not implement or evaluate such negotiation.

Coarsening creates a different ambiguity. The owner sends an explicit `unknown` source-spread value, so the coordinator knows the field was handled, yet the value cannot satisfy wide or narrow. Attack cases need wide spread to support and remain unresolved. Some benign alternatives can still contradict through failure kind or service-error values, so the unresolved count is 20 rather than 40. A coarsened response is therefore more informative about process than a denial but can be equally nondecisive for a particular rule. The implemented cost assigns it zero units because no fine value is released; whether even the existence of the coarse response deserves a charge is a policy choice for a real deployment.

D. Reproducing a result without overstating it

The case manifest is checked by digest before the evaluator writes a CSV. The evaluator refuses an existing output path, requiring a deliberate new result directory or a conscious removal of a prior artifact. This prevents accidental silent replacement of numbers cited by the manuscripts. Each output row records its scenario, seed, strategy, fault, ground-truth attack flag, outcome, unit cost, refinement count, serialized bytes, rounds, and local elapsed time. A reader can independently group rows by strategy and fault and recompute every table in this section. The summary JSON is a convenience view, while the row-level CSV preserves diagnostics when a total changes.

Reproducibility is not the same as independence. The pseudorandom seeds fix event realizations within a generator. They do not sample five new scenario types or three unrelated organizations. The normal and abnormal rates and status-code mappings are explicit in the simulator. If a researcher changes the detector threshold, catalogue order, or source rule, the protocol totals may change even with the same seeds. The scientific object to reproduce is the complete combination of case manifest, code revision, environment, and row-level output. This is why the manuscript confines its quantitative claim to the tested implementation and does not claim a statistically significant privacy or detection improvement.

There is also a construct-validity issue in the term *false positive*. In this experiment it means a benign-labelled synthetic scenario received a `supported` protocol outcome. That is not necessarily a false security alert in operational terms: a flash crowd may deserve attention, and a provider outage is itself an incident. The term is used to compare the declared attack-labelled task. A deployment should report separate labels for malicious activity, service health, and analyst actionability. A single binary attack label cannot capture all three. Likewise, *true positive* here means the rule supports a scenario authored as an attack; it does not verify that the detector would identify an unseen attack in live traffic.

E. Potential adaptations

There are plausible next policies beyond the two fixed schedules and the greedy selector. An owner could provide a signed capability map describing entries it may release at each coarseness, allowing the coordinator to avoid doomed requests. A coordinator could use a prior over benign alternatives to select a more informative predicate first. Or peers could compute a joint threshold using cryptographic techniques, reducing explicit categorical release. Each option shifts a different trade-off: capability maps leak policy, learned priors may be brittle or biased, and cryptographic protocols add computational and key-management cost. The present method deliberately chooses a deterministic finite baseline before those complexities. It gives researchers a concrete reference point for comparing them rather than claiming to dominate all alternatives.

XI. AUTHORIZATION AS A TIME-VARYING INPUT

Permission is evaluated at two times: when the snapshot is constructed for generation and when a report is retrieved. The first check prevents the model from seeing evidence outside the recipient's scope. The second prevents a previously authorized report from being served after permission changes. The stored digest binds output to snapshot contents but is not itself an access token. Guessing a job identifier should not grant access; the API must verify the user and incident scope for every fetch. The pilot's finite scorer does not exercise browser sessions or cross-organization access and therefore

cannot validate those controls; they belong to the application integration tests.

A lifecycle test should include an in-flight job. If permissions are revoked after generation starts but before the worker stores the output, the worker must compare its snapshot digest with the current authorized snapshot before publishing. If the job was completed before revocation, the read path must still deny or mark it stale. There are two race windows, and closing only one is insufficient. The service's current worker and HTTP read paths both check for a digest mismatch; a future formal analysis could state linearization points and prove the absence of a served stale report under concurrent updates.

Authentication and authorization are separate. A valid browser session proves the identity of a user, while incident-scoped permissions determine which snapshots that user may read. A second-laptop model endpoint has a machine credential and TLS channel but no independent right to fetch arbitrary incidents. It receives only the snapshot the API already approved. If that machine is compromised, it can read the snapshots sent to it during its authorized operation. This is a residual risk of moving inference off the primary PC, even though no external cloud provider is contacted.

An authorization check can fail because the database is unavailable. Serving an old report in that state would convert a temporary outage into a disclosure decision. The safer response is a visible unavailable status or a fallback built only after current authorization can be established. The distinction is operationally costly: an analyst may lose an explanation during a database incident. For sensitive cross-organization data, that cost is preferable to silently reusing a stale authorization decision. The evaluation does not quantify that availability trade-off.

XII. Contract Invariants and Their Preconditions

The reference invariant is that every displayed evidence-value sentence names an evidence item in the recipient's current snapshot with the same version and value. This follows from computing allowed tuples from that snapshot and rendering only admitted tuples. It assumes the snapshot constructor has already enforced access and that the renderer does not append unchecked model prose. The invariant does not make the sensor accurate. It does not apply to an image of an earlier report taken before a correction.

The kind invariant is that a partial-coverage field cannot be rendered as a complete observation. The expected-claim constructor maps partial coverage to an unknown claim. The template text says that unavailable evidence cannot establish absence of threat. A model that tries to convert partial coverage into a reassuring observation fails tuple membership. The strength of this rule depends on coverage being accurately represented upstream. If the incident API incorrectly labels a partial snapshot complete, the explanation layer cannot discover the omission.

The version invariant is that a completed report is usable only while its digest matches a newly authorized snapshot for the requesting user. This is enforced on retrieval and also checked by the worker before storing a result. A digest mismatch makes the job stale. The digest is an equality token over snapshot state, not a cryptographic proof of source authenticity. If two distinct security states produce an identical digest through a construction bug, this invariant fails. Testing must therefore include version changes, deactivation, and permission changes and verify that each changes the authorized view or blocks access.

The bounded-attempt invariant is that a model request is attempted at most twice: one initial generation and one repair. This prevents an unbounded autonomous loop. It says nothing about how long either call takes until a timeout is configured and enforced. An exception also ends in deterministic fallback, which keeps detection independent of model availability. The pilot's median generation time shows that the operational limit must be expressed in seconds and resource reservations, not just attempt count.

Finally, the no-action invariant is that the explanation component has no remediation tool. A suggestion to review local logs is represented as advice and rendered as a suggestion to an authorized analyst. It cannot launch a query or change an incident. This reduces the damage from a malicious instruction in evidence. It does not prevent a human analyst from acting on misleading advice, so user-facing labels and review procedures remain part of the larger safety case.

These invariants are deliberately narrow. None claims that the output is a complete, unbiased, or strategically useful account of an incident. A new predicate, renderer, or external delivery channel changes the proof obligations. Treating the verifier as a stable interface requires contract-versioning and regression tests whenever the vocabulary expands. The present study is a reproducible baseline for that work, not a claim of final coverage.

XIII. Limitations and Research Implications

An authenticated source can lie about a value that the verifier faithfully reports. A common upstream failure can affect several nominally separate organizations. Tumbling windows can split campaigns, and the first eligible source snapshot can omit changing conditions. The finite catalogue covers two scenario families; its costs and thresholds are operator choices. Provenance enrollment, host trust, database correctness and independent scope enforcement are preconditions. The work provides no Byzantine consensus, hardware attestation, automatic failover or leakage proof.

The explanation language deliberately excludes arbitrary numerical and causal claims. This makes exact admission possible while reducing expressive power. A stronger model might provide better proposals, but the recorded configuration did not. Smaller task models and alternative local runtimes are possible future comparators, not implemented or evaluated contributions of this study. A broader claim about useful local interpretation requires frozen unseen cases, resource measurements and actual analyst evaluation.

The combined lifecycle exposes a further question: withholding evidence can reduce disclosure while also reducing

what an explanation may say. Our component studies do not quantify that joint trade-off. A future experiment must run shared incident cases through release, correlation, authorization and rendering, measuring disclosure alongside accepted claim coverage and analyst decisions. It should retain unresolved and fallback outcomes rather than excluding them from a success rate. The incomplete CIC-IDS2017 replay remains explicitly outside the reported results.

XIV. Conclusion

A common evidence lifecycle can keep release authority at the source and make displayed claims depend on current recipient permissions. The implemented adaptive protocol reduces disclosure relative to richer sharing within a fixed synthetic workload; policy restrictions leave many cases unresolved. The local explanation contract rejects unsupported and stale tuples, but its eight-case CPU pilot falls back throughout and shows no benefit from generation over templates. Further evaluation must establish realistic detection, joint disclosure/interpretation behavior and analyst usefulness before broader performance claims are justified.

References

[1] C. S. Johnson, M. L. Badger, D. A. Waltermire, J. Snyder, and C. Skorupka, "Guide to Cyber Threat Information Sharing," NIST SP 800-150, 2016, doi: 10.6028/NIST.SP.800-150.

[2] C. Wagner, A. Dulaunoy, G. Wagener, and A. Iklody, "MISP: The Design and Implementation of a Collaborative Threat Intelligence Sharing Platform," in *Proc. ACM WISCS*, 2016, pp. 49–56, doi: 10.1145/2994539.2994542.

[3] J. Freudiger, E. De Cristofaro, and A. E. Brito, "Controlled Data Sharing for Collaborative Predictive Blacklisting," in *Proc. DIMVA*, LNCS vol. 9148, 2015, pp. 327–349, doi: 10.1007/978-3-319-20550-2_17.

[4] B. Jordan, R. Piazza, and T. Darley, Eds., "STIX Version 2.1," OASIS Standard, Jun. 2021. [Online]. Available: https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html

[5] P. Lincoln, P. Porras, and V. Shmatikov, "Privacy-Preserving Sharing and Correlation of Security Alerts," in *Proc. 13th USENIX Security Symp.*, 2004. [Online]. Available: https://www.usenix.org/conference/13th-usenix-security-symposium/privacy-preserving-sharing-and-correlation-security-alerts

[6] M. Burkhart, M. Strasser, D. Many, and X. Dimitropoulos, "SEPIA: Privacy-Preserving Aggregation of Multi-Domain Network Events and Statistics," in *Proc. 19th USENIX Security Symp.*, 2010. [Online]. Available: https://www.usenix.org/events/sec10/tech/full_papers/Burkhart.pdf

[7] O. E. Arpaci, R. Boutaba, and F. Kerschbaum, "Over-Threshold Multiparty Private Set Intersection for Collaborative Network Intrusion Detection," in *Proc. 23rd USENIX NSDI*, 2026, pp. 2211–2226. [Online]. Available: https://www.usenix.org/conference/nsdi26/presentation/arpaci

[8] H.-C. Kum, E. D. Ragan, G. Ilangovan, M. Ramezani, Q. Li, and C. Schmit, "Enhancing Privacy through an Interactive On-demand Incremental Information Disclosure Interface: Applying Privacy-by-Design to Record Linkage," in *Proc. SOUPS*, 2019, pp. 175–189. [Online]. Available: https://www.usenix.org/conference/soups2019/presentation/kum

[9] X. Bouwman *et al.*, "Helping hands: Measuring the impact of a large threat intelligence sharing community," in *Proc. 31st USENIX Security Symp.*, 2022, pp. 1149–1165. [Online]. Available: https://www.usenix.org/conference/usenixsecurity22/presentation/bouwman

[10] M. Rigaki, C. Catania, and S. Garcia, "Hackphyr: A Local Fine-Tuned LLM Agent for Network Security Environments," arXiv:2409.11276, 2024, doi: 10.48550/arXiv.2409.11276.

[11] N. Suryanto *et al.*, "RedSage: A Cybersecurity Generalist LLM," in *Proc. ICLR*, 2026. [Online]. Available: https://openreview.net/pdf?id=W4FAenIrQ2

[12] T. Gao, H. Yen, J. Yu, and D. Chen, "Enabling Large Language Models to Generate Text with Citations," in *Proc. EMNLP*, 2023, pp. 6465–6488, doi: 10.18653/v1/2023.emnlp-main.398.

[13] L. Gao *et al.*, "RARR: Researching and Revising What Language Models Say, Using Language Models," in *Proc. ACL*, vol. 1, 2023, pp. 16477–16508, doi: 10.18653/v1/2023.acl-long.910.

[14] S. Min *et al.*, "FActScore: Fine-grained Atomic Evaluation of Factual Precision in Long Form Text Generation," in *Proc. EMNLP*, 2023, pp. 12076–12100, doi: 10.18653/v1/2023.emnlp-main.741.

[15] M. Atoum, M. Al-Essa, Y. Alsarhan, A. K. A. Hwaitat, and M. Imran, "LLM Enhanced Explainable Intrusion Detection System for Generating Actionable Security Insights," *Computers, Materials & Continua*, vol. 89, no. 2, Art. no. 50, 2026, doi: 10.32604/cmc.2026.085403.

[16] E. Eilertsen, V. Mavroeidis, and G. Grov, "Towards Agentic Investigation of Security Alerts," in *Proc. IEEE BigData*, 2025, pp. 7793–7802, doi: 10.1109/BigData66926.2025.11402161.

[17] F. A. Kamelhar, "GSAR: Typed Grounding for Hallucination Detection and Recovery in Multi-Agent LLMs," arXiv:2604.23366, 2026, doi: 10.48550/arXiv.2604.23366.

[18] Y. T. Shen, K. Toyoda, and A. Leung, "Revoked but Still Authoritative: An Empirical Study of Revocation Enforcement in Agent-Memory Systems," arXiv:2609.08258, 2026, doi: 10.48550/arXiv.2609.08258.

[19] N. Srisumrith and S. Sodsee, "Detecting Cybersecurity Threats by Integrating Explainable AI with SHAP Interpretability and Strategic Data Sampling," arXiv:2602.19087, 2026, doi: 10.48550/arXiv.2602.19087.

[20] X. Hu *et al.*, "Knowledge-Centric Hallucination Detection," in *Proc. EMNLP*, 2024, pp. 6953–6975, doi: 10.18653/v1/2024.emnlp-main.395.

[21] P. Manakul, A. Liusie, and M. Gales, "SelfCheckGPT: Zero-Resource Black-Box Hallucination Detection for Generative Large Language Models," in *Proc. EMNLP*, 2023, pp. 9004–9017, doi: 10.18653/v1/2023.emnlp-main.557.

[22] Y.-N. Chuang *et al.*, "FaithLM: Towards Faithful Explanations for Large Language Models," in *Proc. EACL*, vol. 1, 2026, pp. 3802–3824, doi: 10.18653/v1/2026.eacl-long.177.

[23] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward Generating a New Intrusion Detection Dataset and Intrusion Traffic Characterization," in *Proc. ICISSP*, 2018, pp. 108–116, doi: 10.5220/0006639801080116.

[24] Canadian Institute for Cybersecurity, "Intrusion Detection Evaluation Dataset (CIC-IDS2017)," Univ. of New Brunswick. [Online]. Available: https://www.unb.ca/cic/datasets/ids-2017.html

[25] C. Dwork and A. Roth, "The Algorithmic Foundations of Differential Privacy," *Foundations and Trends in Theoretical Computer Science*, vol. 9, nos. 3–4, pp. 211–407, 2014, doi: 10.1561/0400000042.

[26] A. Serckumecka, I. Medeiros, and A. Bessani, "CCE: A Cloud-Based SIEM Correlation Engine Built on Serverless Functions," in *Proc. IEEE SRDS*, 2025, pp. 95–105, doi: 10.1109/SRDS69199.2025.00022.

[27] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection," in *Proc. ACM AISec*, 2023, pp. 79–90, doi: 10.1145/3605764.3623985.

[28] K. Vaswani *et al.*, "Confidential Computing within an AI Accelerator," in *Proc. USENIX ATC*, 2023, pp. 501–518. [Online]. Available: https://www.usenix.org/conference/atc23/presentation/vaswani

[29] A. Yang *et al.*, "Qwen3 Technical Report," arXiv:2505.09388, 2025, doi: 10.48550/arXiv.2505.09388.

[30] L. Yuan, D.-J. Han, S. Wang, and C. G. Brinton, "Local-Cloud Inference Offloading for LLMs in Multi-Modal, Multi-Task, Multi-Dialogue Settings," in *Proc. ACM MobiHoc*, 2025, pp. 201–210, doi: 10.1145/3704413.3764429.